

Evaluación de riesgos

Introducción y marco metodológico

La evaluación de riesgos constituye el proceso central sobre el cual se construye el Sistema de Gestión de Seguridad de la Información (SGSI) de NovaTech Solutions. A través de este proceso se identifican y priorizan los riesgos que representan una amenaza real para los activos de información críticos de la organización, con el objetivo final de definir controles y estrategias de tratamiento acordes al contexto operativo en que se desenvuelve la empresa.

Para llevar a cabo este análisis se adoptó la metodología OCTAVE Allegro, desarrollada por el CERT/CC de la Universidad Carnegie Mellon. Esta metodología fue seleccionada precisamente porque responde a la necesidad de contar con un proceso sistemático y orientado a los activos de información, sin requerir una infraestructura de gestión de riesgos especialmente compleja. Su estructura resulta compatible con los requisitos de la norma ISO/IEC 27001 y se alinea con el modelo de gestión de riesgos definido en el documento marco del SGSI de la organización.

El proceso se divide en cuatro fases principales que abarcan desde la definición de criterios hasta la respuesta ante el riesgo:

Fase	Pasos	Nombre de la fase	Objetivo
I	Paso 1	Establecer Drivers	Desarrollar los criterios de medición de riesgos consistentes con los drivers organizacionales.
II	Pasos 2 y 3	Perfilar Activos	Identificar y documentar los activos de información críticos y los contenedores donde residen.
III	Pasos 4 y 5	Identificar Amenazas	Identificar áreas de preocupación y desarrollar escenarios de amenaza detallados.
IV	Pasos 6, 7 y 8	Identificar y Mitigar Riesgos	Identificar riesgos, calcular puntajes y seleccionar estrategias de mitigación.

La metodología se divide en dos grandes procesos complementarios que permiten pasar de la identificación técnica a la toma de decisiones estratégica:

Análisis de Riesgos	Evaluación de Riesgos
Proceso de identificación de amenazas, vulnerabilidades y activos, estimando la probabilidad e impacto de cada riesgo. Responde a: ¿qué podría salir mal, con qué probabilidad y qué tan grave sería?	Proceso de comparación de los resultados del análisis contra los criterios de riesgo de la organización, para determinar si cada riesgo es aceptable o requiere tratamiento. Responde a: ¿qué hará la organización con cada riesgo?
Resultado: lista de riesgos identificados con nivel de probabilidad e impacto estimado.	Resultado: decisión de estrategia de tratamiento — mitigar, aceptar, transferir o evitar.

Fase I

Paso 1. Establecimiento de criterios de medición de riesgos

Con base en el contexto organizacional de NovaTech Solutions y las áreas de preocupación identificadas por la dirección, se tienen las siguientes áreas de impacto ordenadas por prioridad:

- Reputación y confianza del cliente (prioridad 1): NovaTech Solutions sustenta su crecimiento en la confianza de sus clientes. Un incidente que afecte la confidencialidad o disponibilidad de sus servicios tiene un impacto directo en su posicionamiento en el mercado y sus relaciones comerciales.
- Legal y regulatorio (prioridad 2): La organización maneja datos personales de clientes y empleados sujetos a la LFPDPPP. El incumplimiento de esta ley puede generar sanciones administrativas, multas y demandas.
- Financiero (prioridad 3): Los incidentes de seguridad generan costos directos adquiridos de la recuperación, compensaciones a clientes, lucro cesante y posibles multas regulatorias.
- Productividad y operaciones (prioridad 4): La interrupción de los sistemas críticos afecta la capacidad de la organización de entregar sus servicios y cumplir sus acuerdos o convenios.
- Seguridad del personal (prioridad 5): Aplica en situaciones donde la exposición de datos sensibles ponga en riesgo la integridad física o la privacidad del personal de la organización.

Fase II

Paso 2. Selección de activos críticos de información

Con base en el inventario de activos de información, se seleccionan para el análisis completo los activos que presentan un nivel de criticidad Crítico (4), dado que su compromiso representaría el mayor impacto para la organización:

- DA-01 — Base de datos de clientes (CRM): Contiene datos personales protegidos por la LFPDPPP. Su compromiso genera responsabilidad legal directa y afecta la confianza de los clientes.
- DA-03 — Información financiera y contable: Soporta la continuidad financiera del negocio. Su pérdida, alteración o divulgación no autorizada genera un impacto financiero y legal grave.
- DA-05 — Credenciales de acceso a sistemas: Su compromiso constituye el vector de ataque más frecuente y puede derivar en el acceso no autorizado a todos los demás activos de la organización.
- SW-01 — Código fuente de plataformas propias: Representa la propiedad intelectual central de NovaTech Solutions. Su filtración o modificación no autorizada afecta múltiples proyectos y la confianza de los clientes.
- SW-04 — Repositorios Git (control de versiones): Contienen el historial completo del código fuente. Un acceso no autorizado compromete la integridad de todos los desarrollos activos.
- SW-06 — Plataformas web en producción para clientes: Representan el servicio que organización entrega directamente a sus clientes. Su interrupción o compromiso afecta la continuidad del negocio y la reputación de la empresa.
- IN-01 — Servidores en la nube (entorno de producción): Constituyen la infraestructura que soporta todos los servicios digitales. Su falla tiene impacto directo en la disponibilidad de la totalidad del negocio.

Paso 3. Identificación de contenedores de activos

Para cada activo crítico se identifican los contenedores en los que se almacena, procesa o transmite, clasificados en técnicos, físicos y humanos:

DA-01 — Base de datos de clientes

- **Contenedores técnicos:** Servidor de base de datos en la nube, sistema CRM y respaldos automatizados.
- **Contenedores físicos:** Centro de datos del proveedor de servicios en la nube.
- **Contenedores humanos:** Personal del área de atención a clientes y equipo de TI.

DA-03 — Información financiera y contable

- **Contenedores técnicos:** Sistema ERP, servidores de archivos y correo electrónico corporativo.
- **Contenedores físicos:** Oficinas del área de administración en Monterrey, México.
- **Contenedores humanos:** Director Administrativo y personal de contabilidad.

DA-05 — Credenciales de acceso a sistemas

- **Contenedores técnicos:** Gestores de contraseñas, sistemas de autenticación y directorio activo.
- **Contenedores físicos:** Equipos de cómputo del personal en las instalaciones de la organización.
- **Contenedores humanos:** Todo el personal con acceso a sistemas de la organización.

SW-01 — Código fuente de plataformas propias

- **Contenedores técnicos:** Repositorios Git, servidores CI/CD y ambientes de desarrollo y pruebas.
- **Contenedores físicos:** Centro de datos del proveedor de servicios en la nube.
- **Contenedores humanos:** Equipo de desarrollo de software, aproximadamente 20 personas.

SW-04 — Repositorios Git

- **Contenedores técnicos:** Plataforma de control de versiones y servidores de integración continua.
- **Contenedores físicos:** Centro de datos del proveedor de servicios en la nube.
- **Contenedores humanos:** Equipo de desarrollo de software y personal de DevOps.

SW-06 — Plataformas web en producción

- **Contenedores técnicos:** Servidores de producción, red de distribución de contenidos (CDN) y bases de datos de clientes.
- **Contenedores físicos:** Centro de datos del proveedor de servicios en la nube.
- **Contenedores humanos:** Equipo de desarrollo y clientes externos de NovaTech Solutions.

IN-01 — Servidores en la nube

- **Contenedores técnicos:** Panel de administración del proveedor cloud y herramientas de monitoreo y DevOps.
- **Contenedores físicos:** Centro de datos del proveedor de servicios en la nube.
- **Contenedores humanos:** Responsable de TI, personal de DevOps y directivos con acceso administrativo.

Fase III

Pasos 4 y 5. Identificación de áreas de preocupación y escenarios de amenaza

A partir de los activos y contenedores definidos en los pasos anteriores, se identificaron diez escenarios de amenaza relevantes para la organización. Vale destacar que tres de ellos no son meramente hipotéticos: corresponden a situaciones que NovaTech Solutions ya ha experimentado en su operación.

AM-01 — Extracción de base de datos de clientes por agente externo

ID Escenario	AM-01	Activo afectado	DA-01 — Base de datos de clientes
Categoría de amenaza	Divulgación no autorizada	Caso	Hipotético
ÁREA DE PREOCUPACIÓN (Paso 4)			
(1) Actor	Agente externo — Atacante remoto		
(2) Medio / Método	Explotación de vulnerabilidad en la aplicación web (inyección SQL, autenticación débil) para acceder directamente a la base de datos CRM.		
(3) Motivo	Obtener datos personales para venta en mercados clandestinos, chantaje o espionaje competitivo.		
(4) Resultado sobre el activo	Divulgación		
(5) Requisito de seguridad afectado	Confidencialidad — datos personales de clientes expuestos sin autorización.		
(6) Probabilidad	Alto		
(7) Consecuencias para la organización	Violación de la LFPDPPP con multas. Pérdida de confianza de clientes. Daño reputacional de largo plazo		

AM-02 — Envío accidental de datos de clientes por correo electrónico

ID Escenario	AM-02	Activo afectado	DA-01 — Base de datos de clientes
Categoría de amenaza	Divulgación no autorizada	Caso	Ocurrió en la organización
ÁREA DE PREOCUPACIÓN (Paso 4)			
(1) Actor	Agente interno — Empleado del área de atención a clientes		
(2) Medio / Método	Reenvío accidental de conversación de soporte con datos del cliente a una dirección de correo incorrecta.		
(3) Motivo	Error humano sin intención maliciosa.		
(4) Resultado sobre el activo	Divulgación		
(5) Requisito de seguridad afectado	Confidencialidad — datos personales y técnicos del cliente expuestos a tercero no autorizado.		
(6) Probabilidad	Alto		
(7) Consecuencias para la organización	Incumplimiento de la LFPDPPP. Queja formal del cliente. Reputación afectada. Posible demanda por parte del cliente afectado.		

AM-03 — Robo de credenciales mediante phishing

ID Escenario	AM-03	Activo afectado	DA-05 — Credenciales de acceso
Categoría de amenaza	Acceso no autorizado	Caso	Hipotético
ÁREA DE PREOCUPACIÓN (Paso 4)			
(1) Actor	Agente interno — Atacante mediante ingeniería social		
(2) Medio / Método	Correo electrónico de phishing dirigido (spear phishing) suplantando identidad de proveedor o servicio interno para robar credenciales.		
(3) Motivo	Obtener acceso privilegiado a los sistemas internos de NovaTech para extracción de datos o sabotaje.		
(4) Resultado sobre el activo	Divulgación		
(5) Requisito de seguridad afectado	Confidencialidad — credenciales del empleado expuestas; acceso no autorizado a sistemas con sus privilegios.		

(6) Probabilidad	Alto
(7) Consecuencias para la organización	Acceso no autorizado a múltiples sistemas. Posible exfiltración de datos de clientes y código fuente. Escalada de privilegios.

AM-04 — Acceso no autorizado a repositorios Git por sesión no cerrada

ID Escenario	AM-04	Activo afectado	SW-04 — Repositorios Git
Categoría de amenaza	Acceso no autorizado	Caso	Ocurrió en la organización
ÁREA DE PREOCUPACIÓN (Paso 4)			
(1) Actor	Agente externo — Persona con acceso físico a equipo compartido		
(2) Medio / Método	Uso de sesión activa de un desarrollador que olvidó cerrar sesión en un equipo compartido durante visita a cliente, accediendo desde IP externa.		
(3) Motivo	Obtención de código fuente propietario para uso indebido, reventa o ventaja competitiva.		
(4) Resultado sobre el activo	Divulgación		
(5) Requisito de seguridad afectado	Confidencialidad — código fuente descargado sin autorización por actor externo.		
(6) Probabilidad	Alto		
(7) Consecuencias para la organización	Exposición de propiedad intelectual. Riesgo de filtración de lógica de negocio. Imposibilidad de confirmar alcance del acceso.		

AM-05 — Inyección de código malicioso en rama de producción

ID Escenario	AM-05	Activo afectado	SW-01 — Código fuente de plataformas propias
Categoría de amenaza	Modificación no autorizada	Caso	Hipotético
ÁREA DE PREOCUPACIÓN (Paso 4)			
(1) Actor	Agente externo o interno — Actor con acceso a repositorios		
(2) Medio / Método	Inyección de código malicioso (backdoor, malware) en una rama del repositorio que posteriormente se fusiona a producción sin detección.		

(3) Motivo	Comprometer los sistemas de múltiples clientes simultáneamente, robar datos o crear puertas traseras de acceso.
(4) Resultado sobre el activo	Modificación
(5) Requisito de seguridad afectado	Integridad — el código fuente es alterado sin autorización, comprometiendo la confiabilidad del software.
(6) Probabilidad	Medio
(7) Consecuencias para la organización	Compromiso de plataformas de múltiples clientes. Daño reputacional masivo. Responsabilidad legal frente a clientes afectados. Costos de remediación elevados.

AM-06 — Ataque DDoS a plataformas web en producción

ID Escenario	AM-06	Activo afectado	SW-06 — Plataformas web en producción
Categoría de amenaza	Interrupción del servicio	Caso	Hipotético
ÁREA DE PREOCUPACIÓN (Paso 4)			
(1) Actor	Agente externo — Atacante		
(2) Medio / Método	Ataque de denegación de servicio distribuido (DDoS) dirigido a las plataformas web que NovaTech opera para sus clientes.		
(3) Motivo	Dañar la reputación de NovaTech, afectar a clientes específicos o extorsionar para detener el ataque.		
(4) Resultado sobre el activo	Interrupción		
(5) Requisito de seguridad afectado	Disponibilidad — el servicio queda inaccesible para los usuarios finales.		
(6) Probabilidad	Medio		
(7) Consecuencias para la organización	Pérdida de ingresos por compensaciones. Daño reputacional. Posible pérdida de clientes.		

AM-07 — Ransomware en servidores de producción

ID Escenario	AM-07	Activo afectado	IN-01 — Servidores en la nube
Categoría de amenaza	Pérdida o destrucción	Caso	Hipotético
ÁREA DE PREOCUPACIÓN (Paso 4)			
(1) Actor	Agente externo — Atacante con acceso a los servidores (malware)		
(2) Medio / Método	Ransomware que cifra los servidores de producción, dejando inaccesibles todos los servicios y datos.		
(3) Motivo	Extorsión económica. Solicitud de rescate para restaurar el acceso a los sistemas.		
(4) Resultado sobre el activo	Destrucción		
(5) Requisito de seguridad afectado	Disponibilidad e Integridad — los servidores y datos quedan inutilizables hasta pago del rescate o restauración.		
(6) Probabilidad	Medio		
(7) Consecuencias para la organización	Caída total de todos los servicios. Pérdida potencial de datos sin backup. Costos del rescate o recuperación.		

AM-08 — Fraude interno mediante alteración de registros financieros

ID Escenario	AM-08	Activo afectado	DA-03 — Información financiera
Categoría de amenaza	Modificación no autorizada	Caso	Hipotético
ÁREA DE PREOCUPACIÓN (Paso 4)			
(1) Actor	Agente interno — Empleado		

(2) Medio / Método	Alteración intencional de registros financieros para encubrir fraude, desvío de fondos o beneficio personal.
(3) Motivo	Ganancia económica personal o encubrimiento de irregularidades.
(4) Resultado sobre el activo	Modificación
(5) Requisito de seguridad afectado	Integridad — los registros financieros son alterados sin autorización, comprometiendo su veracidad.
(6) Probabilidad	Bajo
(7) Consecuencias para la organización	Responsabilidad penal y fiscal. Auditorías externas obligatorias. Pérdida de confianza de inversionistas y socios.

AM-09 — Caída de sistemas por mala configuración en actualización

ID Escenario	AM-09	Activo afectado	IN-01 — Servidores en la nube
Categoría de amenaza	Interrupción del servicio	Caso	Ocurrió en la organización
ÁREA DE PREOCUPACIÓN (Paso 4)			
(1) Actor	Error interno — Falla operativa		
(2) Medio / Método	Configuración incorrecta aplicada durante una actualización del servidor que provoca la caída del sistema CRM y otros servicios críticos.		
(3) Motivo	Error humano no intencional durante procedimiento de mantenimiento.		
(4) Resultado sobre el activo	Interrupción		
(5) Requisito de seguridad afectado	Disponibilidad — los servicios críticos quedan inaccesibles por error de configuración.		
(6) Probabilidad	Alto		
(7) Consecuencias para la organización	Interrupción en horas de servicio. Frustración y quejas de clientes. Pérdida de productividad interna.		

AM-10 — Acceso no autorizado por sesión activa en equipo compartid

ID Escenario	AM-10	Activo afectado	SW-04 — Repositorios Git
---------------------	--------------	------------------------	--------------------------

Categoría de amenaza	Acceso no autorizado	Caso	Ocurrió en la organización
ÁREA DE PREOCUPACIÓN (Paso 4)			
(1) Actor	Agente externo — Persona con acceso a sesión activa		
(2) Medio / Método	Sesión activa de un desarrollador no cerrada en un equipo permite acceso desde IP desconocida.		
(3) Motivo	Acceso oportunista a código fuente o recursos internos.		
(4) Resultado sobre el activo	Divulgación		
(5) Requisito de seguridad afectado	Confidencialidad — acceso a repositorios con credenciales de empleado sin su conocimiento.		
(6) Probabilidad	Medio		
(7) Consecuencias para la organización	Descarga de componentes de código. Incertidumbre sobre el alcance del acceso. Riesgo latente de uso indebido del código.		

Fase IV

Paso 6. Identificación de vulnerabilidades

A partir del análisis de los escenarios anteriores se identificaron las siguientes vulnerabilidades organizacionales, técnicas y humanas que incrementan la probabilidad de materialización de dichas amenazas:

ID	Condición de riesgo	Escenarios que afecta	Tipo
VU-01	Ausencia de política formal de control de accesos	AM-01, AM-03, AM-04, AM-08	Organizacional
VU-02	Ausencia de autenticación multifactor (MFA)	AM-03, AM-04, AM-10	Técnica
VU-03	Ausencia de monitoreo de accesos anómalos	AM-01, AM-04, AM-07	Técnica
VU-04	Capacitación limitada en seguridad de la información	AM-02, AM-03, AM-09	Humana
VU-05	Ausencia de plan de respuesta a incidentes	Todos los escenarios	Organizacional

VU-06	Ausencia de plan de continuidad del negocio	AM-06, AM-07, AM-09	Organizacional
VU-07	Acumulación de privilegios de acceso no revisados	AM-01, AM-03, AM-05	Técnica/Organizacional
VU-08	Control deficiente sobre dispositivos compartidos	AM-04, AM-10	Técnica

Paso 7. Análisis y cálculo del puntaje de riesgo

Para determinar el nivel de riesgo de cada escenario se empleó una escala de valoración del 1 al 3, aplicada tanto a la probabilidad de ocurrencia como al impacto en cada una de las áreas definidas en el Paso 1 (donde 1 = bajo, 2 = medio y 3 = alto). La fórmula aplicada es la siguiente:

$$\text{Puntaje} = \text{Probabilidad} \times (\text{Impacto en reputación} \times 1 + \text{Impacto legal} \times 2 + \text{Impacto financiero} \times 3 + \text{Impacto en operaciones} \times 4)$$

Los rangos de interpretación son: 1 a 15 = Bajo; 16 a 30 = Medio; 31 a 50 = Alto; 51 en adelante = Crítico.

AM-05 — Inyección de código malicioso en rama de producción

Área de Impacto	Ponderación	Puntuación (1-3)	Criterio aplicado	Subtotal
Reputación y confianza del cliente	× 1	3	Alto	3
Legal y regulatorio	× 2	3	Alto	6
Financiero	× 3	3	Alto	9
Productividad y operaciones	× 4	3	Alto	12
			Puntaje	52
NIVEL DE RIESGO				CRÍTICO

AM-07 — Ransomware en servidores de producción

Área de Impacto	Ponderación	Puntuación (1-3)	Criterio aplicado	Subtotal
Reputación y confianza del cliente	× 1	3	Alto	3
Legal y regulatorio	× 2	2	Medio	4
Financiero	× 3	3	Alto	9
Productividad y operaciones	× 4	3	Alto	12
			Puntaje	44
NIVEL DE RIESGO				CRÍTICO

AM-04 — Acceso no autorizado a repositorios Git

Área de Impacto	Ponderación	Puntuación (1-3)	Criterio aplicado	Subtotal
Reputación y confianza del cliente	× 1	3	Alto	3
Legal y regulatorio	× 2	2	Medio	4
Financiero	× 3	3	Alto	9
Productividad y operaciones	× 4	2	Medio	8
			Puntaje	42
NIVEL DE RIESGO				CRÍTICO

AM-01 — Extracción de base de datos de clientes

Área de Impacto	Ponderación	Puntuación (1-3)	Criterio aplicado	Subtotal
Reputación y confianza del cliente	× 1	3	Alto	3
Legal y regulatorio	× 2	3	Alto	6
Financiero	× 3	3	Alto	9
Productividad y operaciones	× 4	2	Medio	8
			Puntaje	42
NIVEL DE RIESGO				CRÍTICO

AM-03 — Phishing con robo de credenciales

Área de Impacto	Ponderación	Puntuación (1-3)	Criterio aplicado	Subtotal
Reputación y confianza del cliente	× 1	2	Medio	2
Legal y regulatorio	× 2	2	Medio	4
Financiero	× 3	2	Medio	6
Productividad y operaciones	× 4	3	Alto	12
			Puntaje	39
NIVEL DE RIESGO				CRÍTICO

AM-06 — Ataque DDoS a plataformas web

Área de Impacto	Ponderación	Puntuación (1-3)	Criterio aplicado	Subtotal
Reputación y confianza del cliente	× 1	2	Medio	2
Legal y regulatorio	× 2	1	Bajo	2
Financiero	× 3	2	Medio	6
Productividad y operaciones	× 4	3	Alto	12
			Puntaje	32
NIVEL DE RIESGO				ALTO

AM-02 — Envío accidental de datos de clientes por correo

Área de Impacto	Ponderación	Puntuación (1-3)	Criterio aplicado	Subtotal
Reputación y confianza del cliente	× 1	2	Medio	2
Legal y regulatorio	× 2	3	Alto	6

Financiero	× 3	1	Bajo	3
Productividad y operaciones	× 4	1	Bajo	4
			Puntaje	30
NIVEL DE RIESGO				ALTO

AM-09 — Caída de sistemas por mala configuración

Área de Impacto	Ponderación	Puntuación (1-3)	Criterio aplicado	Subtotal
Reputación y confianza del cliente	× 1	1	Bajo	1
Legal y regulatorio	× 2	1	Bajo	2
Financiero	× 3	2	Medio	6
Productividad y operaciones	× 4	3	Alto	12
			Puntaje	28
NIVEL DE RIESGO				ALTO

AM-08 — Fraude interno en registros financieros

Área de Impacto	Ponderación	Puntuación (1-3)	Criterio aplicado	Subtotal
Reputación y confianza del cliente	× 1	2	Medio	2
Legal y regulatorio	× 2	3	Alto	6
Financiero	× 3	3	Alto	9
Productividad y operaciones	× 4	1	Bajo	4
			Puntaje	18
NIVEL DE RIESGO				MEDIO

AM-10 — Acceso por sesión activa en equipo compartido

Área de Impacto	Ponderación	Puntuación (1-3)	Criterio aplicado	Subtotal
Reputación y confianza del cliente	× 1	1	Alto	1
Legal y regulatorio	× 2	1	Alto	2
Financiero	× 3	1	Alto	3
Productividad y operaciones	× 4	1	Alto	4
			Puntaje	16
NIVEL DE RIESGO				MEDIO

Paso 8. Selección del enfoque de mitigación de riesgos

Una vez calculados los puntajes de riesgo, se determinó la estrategia de tratamiento más adecuada para cada escenario, considerando los criterios definidos por la organización y las capacidades reales de implementación del equipo de seguridad.

AM-05 — Inyección de código malicioso | CRÍTICO

- **Estrategia:** Mitigar
- **Acciones propuestas:** Implementar revisiones obligatorias de código (code review), análisis de seguridad estático (SAST), firma de commits y protección de la rama principal mediante aprobación previa, conforme a las responsabilidades del área de desarrollo establecidas en el documento marco del SGSI.

AM-07 — Ransomware en servidores | CRÍTICO

- **Estrategia:** Mitigar
- **Acciones propuestas:** Las acciones propuestas incluyen la implementación de respaldos offline cifrados con verificación periódica, la adopción de soluciones de detección y respuesta en endpoints (EDR) y la activación formal de un plan de continuidad del negocio.

AM-04 — Acceso no autorizado a repositorios Git | CRÍTICO

- **Estrategia:** Mitigar
- **Acciones propuestas:** Habilitar autenticación multifactor (MFA) en la plataforma de control de versiones, establecer una política de cierre de sesión automático y realizar revisión periódica de permisos en los repositorios.

AM-01 — Extracción de base de datos de clientes | CRÍTICO

- **Estrategia:** Mitigar
- **Acciones propuestas:** Implementar firewall de aplicaciones web (WAF), cifrado de la base de datos en reposo y en tránsito, control de acceso basado en roles (RBAC) y monitoreo de consultas anómalas.

AM-03 — Phishing con robo de credenciales | CRÍTICO

- **Estrategia:** Mitigar
- **Acciones propuestas:** Implementar la autenticación multifactor en todos los sistemas críticos, ejecutar campañas periódicas de capacitación antiphishing y configurar filtros avanzados de correo (SPF, DKIM, DMARC).

AM-06 — Ataque DDoS a plataformas web | ALTO

- **Estrategia:** Transferir / Mitigar
- **Acciones propuestas:** Contratar un servicio de protección anti-DDoS con el proveedor de servicios en la nube y configurar mecanismos de limitación de tráfico en los servidores de producción.

AM-02 — Envío accidental de datos de clientes | ALTO

- **Estrategia:** Mitigar
- **Acciones propuestas:** Implementar herramientas de prevención de pérdida de datos (DLP) en el correo corporativo, establecer una política de manejo de información confidencial y ejecutar capacitaciones periódicas al área de atención a clientes.

AM-09 — Caída de sistemas por mala configuración | ALTO

- **Estrategia:** Mitigar
- **Acciones propuestas:** Establecer un proceso formal de gestión de cambios que exija la validación en ambientes de pre-producción antes de cualquier despliegue en entornos productivos.

AM-08 — Fraude interno en registros financieros | MEDIO

- **Estrategia:** Mitigar
- **Acciones propuestas:** Implementar segregación de funciones en el área administrativa, requerir doble autorización en transacciones financieras y realizar auditorías periódicas de accesos a la información financiera.

AM-10 — Acceso por sesión activa en equipo compartido | MEDIO

- **Estrategia:** Mitigar
- **Acciones propuestas:** Establecer cierre automático de sesión por inactividad en todos los sistemas y prohibir el acceso a sistemas críticos desde equipos compartidos o no corporativos.

Resumen de resultados de la evaluación de riesgos

Los resultados de la evaluación de riesgos realizada a NovaTech Solutions presentan un panorama que exige atención inmediata en múltiples frentes. La distribución de los escenarios por nivel de riesgo es la siguiente:

ID	Escenario de Amenaza	Activo Afectado	Puntaje	Nivel	Estrategia
AM-05	Inyección de código malicioso en rama de producción	SW-01 — Código fuente	52	CRÍTICO	Mitigar
AM-07	Ransomware en servidores de producción	IN-01 — Servidores	44	CRÍTICO	Mitigar
AM-04	Acceso no autorizado a repositorios Git	SW-04 — Repositorios Git	42	CRÍTICO	Mitigar
AM-01	Extracción de base de datos de clientes	DA-01 — CRM	42	CRÍTICO	Mitigar
AM-03	Phishing con robo de credenciales	DA-05 — Credenciales	39	CRÍTICO	Mitigar
AM-06	Ataque DDoS a plataformas web	SW-06 — Producción	32	ALTO	Transferir / Mitigar
AM-02	Envío accidental de datos por correo	DA-01 — CRM	30	ALTO	Mitigar
AM-09	Caída de sistemas por mala configuración	IN-01 — Servidores	28	ALTO	Mitigar
AM-08	Fraude interno en registros financieros	DA-03 — Financiero	18	MEDIO	Mitigar
AM-10	Acceso por sesión activa en equipo compartido	SW-04 — Repositorios Git	16	MEDIO	Mitigar

En términos generales, los hallazgos sitúan a NovaTech Solutions en un nivel de riesgo crítico. Las principales causas de esta situación son la inexistencia de controles de acceso formalizados, la ausencia de autenticación multifactor en activos clave y la falta de planes de continuidad validados.

De acuerdo con el marco metodológico adoptado, el Comité de Seguridad de la Información tendrá la responsabilidad de supervisar estos riesgos a través de revisiones semestrales, con el objetivo de garantizar una gestión dinámica que se ajuste a la evolución del entorno operativo y a las necesidades cambiantes de la organización.